

UNIVERSIDAD DE SALAMANCA

GRADO EN INGENIERIA INFORMATICA

ANEXO V

Plan de Seguridad

Sistema de Gestion Documental mediante Blockchain



David Pérez Velasco

Tutores:

Gabriel Villarrubia González

Sergio García González

Julio 2026

Trabajo de Fin de Grado

Índice

1. Introduccion	4
2. Etapa 1: Identificacion de activos	4
2.1. Activos de hardware	4
2.2. Activos de software	4
2.3. Activos de datos	5
2.4. Activos de servicios	6
2.5. Activos de personal	6
2.6. Resumen consolidado de activos	6
3. Etapa 2: Valoracion de activos	7
3.1. Criterios de valoracion	7
3.2. Escala de valoracion	8
3.3. Valoracion por activo	8
4. Etapa 3: Amenazas principales	9
4.1. Amenazas fisicas	10
4.2. Amenazas logicas	10
4.3. Amenazas de denegacion de servicio	11
4.4. Amenazas de ingenieria social	11
4.5. Amenazas de configuracion y errores operativos	12
4.6. Amenazas especificas de blockchain	12
4.7. Amenazas criptograficas	13
4.8. Amenazas de terceros y cadena de suministro	13
4.9. Resumen consolidado de amenazas principales	13
5. Etapa 4: Consecuencias y probabilidad	14
5.1. Escala de impacto	14
5.2. Matriz de riesgos inherente	15
5.3. Clasificacion del riesgo	15
5.4. Medidas de mitigacion propuestas para riesgos altos	16
6. Etapa 5: Medidas de seguridad	17
6.1. Medidas de prevencion	17
6.2. Medidas de deteccion	17
6.3. Medidas de correccion	18
6.4. Medidas de proteccion de datos	18
6.5. Medidas especificas de blockchain	18
6.6. Tabla resumen de medidas implementadas	19
7. Proteccion de datos y privacidad	21
7.1. Marco regulatorio: RGPD y eIDAS	21
7.2. Derechos de los usuarios	21
7.3. Encriptacion y almacenamiento seguro	22
7.3.1. Cifrado en reposo	22
7.3.2. Cifrado en transito	22
7.3.3. Cifrado de contenido (AES-256-GCM)	22
7.4. Control de acceso y autenticacion	22
7.4.1. Autenticacion basada en JWT	22
7.4.2. Autorizacion RBAC y ABAC	23

7.4.3. Control de acceso on-chain	23
8. Componentes criticos del software	23
8.1. Backend y API REST	23
8.1.1. Medidas de seguridad del backend	23
8.2. Base de datos, IPFS y blockchain	24
8.2.1. Copias de seguridad y redundancia	24
8.2.2. Validacion de integridad	24
8.3. Frontend y gestion de sesiones	24
8.3.1. Proteccion contra vulnerabilidades web	25
8.3.2. Experiencia de usuario segura	25
8.4. Smart contracts	25
8.4.1. Medidas especificas de seguridad en Solidity	25
9. Etapa 6: Riesgos residuales	26
9.1. Tabla de riesgos residuales	26
9.2. Plan de aceptacion de riesgos	27
9.3. Plan de mejora continua	27
10. Metodologias y herramientas	28
10.1. Marcos metodologicos	28
10.2. Herramientas de seguridad	28
10.2.1. Analisis estatico de smart contracts	29
10.2.2. Pruebas de seguridad de aplicaciones web	29
10.3. Metodologia de pentesting aplicada	29
10.4. Politica de actualizacion de dependencias	30
11. Conclusiones	31
Glosario	31

1. Introduccion

Este anexo recoge el plan de seguridad de DocumentChain siguiendo la metodologia del Plan Director de Seguridad del INCIBE. El plan se organiza en seis etapas: identificacion de activos, valoracion, amenazas, consecuencias y probabilidad, medidas de seguridad y riesgos residuales. A lo largo de estas etapas se han identificado los activos criticos del sistema, se han valorado segun su importancia, se han catalogado las amenazas principales y se han definido las medidas necesarias para reducirlas.

2. Etapa 1: Identificacion de activos

Se han identificado los activos del sistema dividiendolos en cinco categorias: hardware, software, datos, servicios y personal. Para cada uno se indica su responsable, ubicacion y nivel de criticidad.

2.1. Activos de hardware

Los activos fisicos soportan la ejecucion y disponibilidad del sistema. Aunque gran parte de la infraestructura se despliega en entornos virtualizados (VPS en cloud), su naturaleza fisica subyacente determina la necesidad de acuerdos de nivel de servicio (SLA) y copias de seguridad geograficas.

ID	Activo	Descripcion	Propietario	Ubicacion	Criticidad
A-H01	VPS principal	Servidor virtual privado que aloja backend, frontend y base de datos	Desarrollador	Cloud provider	Alta
A-H02	Portatil de desarrollo	Equipo local utilizado para el desarrollo, pruebas y gestion de claves	Desarrollador	Local (oficina)	Alta
A-H03	Nodo IPFS	Nodo Kubo que gestiona el almacenamiento distribuido de contenido documental	Desarrollador / Red IPFS	Cloud / local	Alta
A-H04	Infraestructura de red	Routers, firewalls y balanceadores que gestionan el trafico	Proveedor cloud	Cloud provider	Media

Cuadro 1: Inventario de activos de hardware

2.2. Activos de software

Los activos de software engloban el codigo fuente, los sistemas gestores de datos, los contratos inteligentes desplegados y los certificados digitales que garantizan la confidencialidad de las comunicaciones.

ID	Activo	Descripcion	Propietario	Ubicacion
A-S01	Codigo fuente	Repositorios del frontend (React), backend (Node.js) y smart contracts (Solidity)	Desarrollador	GitHub (privado)
A-S02	Base de datos PostgreSQL	Sistema gestor de base de datos relacional con metadatos, permisos y logs	Desarrollador	VPS principal
A-S03	Smart contracts	Conjunto de contratos inteligentes desplegados en red Ethereum (DocumentRegistry, contrato consolidado)	Desarrollador / Red Ethereum	Blockchain publico
A-S04	Certificados SSL/TLS	Certificados digitales para establecimiento de canales seguros HTTPS	Desarrollador / CA	VPS principal
A-S05	Imagenes Docker	Contenedores de los servicios (backend, frontend, IPFS, PostgreSQL, Postfix)	Desarrollador	Registro Docker
A-S06	Scripts de despliegue	Automatizacion de infraestructura (Docker Compose, scripts PowerShell)	Desarrollador	Repositorio Git

Cuadro 2: Inventario de activos de software

2.3. Activos de datos

Los activos de datos representan la informacion que el sistema gestiona, almacena o transmite. Su proteccion es prioritaria dado que DocumentChain maneja documentos potencialmente sensibles y datos personales sujetos al RGPD.

ID	Activo	Descripcion	Propietario	Ubicacion
A-D01	Documentos cifrados	Archivos digitales cifrados con AES-256-GCM	Usuario final / Desarrollador	IPFS
A-D02	Claves simetricas	Claves de cifrado de documentos encapsuladas con RSA/ECDH	Usuario final	PostgreSQL
A-D03	Claves privadas blockchain	Claves de wallets Ethereum de usuarios y administradores	Usuario final	Metadatos
A-D04	Hashes blockchain	Hashes de documentos y metadatos inmutables registrados on-chain	Desarrollador / Red Ethereum	Blockchain
A-D05	Datos personales (RGPD)	Nombre, correo electronico, direccion IP, direccion de wallet, registros de actividad	Usuario final	PostgreSQL
A-D06	Tokens JWT y refresh	Tokens de sesion y tokens de renovacion	Usuario final	Memoria
A-D07	Tokens de verificacion y recuperacion	Tokens temporales para verificar email y restablecer contraseña	Usuario final	PostgreSQL

Cuadro 3: Inventario de activos de datos

2.4. Activos de servicios

Los servicios son las capacidades operativas que el sistema pone a disposicion de los usuarios y de otros componentes internos. Su indisponibilidad afecta directamente a la continuidad del negocio.

ID	Activo	Descripcion	Propietario
A-SV01	API REST	Interfaz de programacion que expone la logica de negocio del backend	Desarrollador
A-SV02	Nodo blockchain (Hardhat / red de pruebas)	Conexion a la red Ethereum para despliegue y consulta de contratos	Desarrollador / Red Ethereum
A-SV03	Servicio de email SMTP	Postfix para envio de notificaciones, verificaciones y alertas	Desarrollador
A-SV04	Servicio de notificaciones push	Notificaciones en tiempo real mediante WebSockets (Socket.io)	Desarrollador
A-SV05	Servicio de auditoria	Registro y consulta de eventos de seguridad y operativos	Desarrollador

Cuadro 4: Inventario de activos de servicios

2.5. Activos de personal

El factor humano constituye tanto un activo como un vector de riesgo. La capacitacion, la segregacion de funciones y la gestion de accesos privilegiados son medidas esenciales para mitigar los riesgos asociados.

ID	Activo	Descripcion	Rol	Acceso
A-P01	Desarrollador / administrador	Responsable del desarrollo, despliegue y mantenimiento del sistema	Administrador	Total
A-P02	Tutores academicos	Supervision tecnica y revision del proyecto	Auditor / Consultor	Limitado (lectura)
A-P03	Usuarios finales registrados	Usuarios que suben, comparten y firman documentos	Usuario estandar	Autorizado por pe
A-P04	Auditor publico	Visitante sin cuenta que verifica documentos mediante hash	Publico	Solo lectura (verifi

Cuadro 5: Inventario de activos de personal

2.6. Resumen consolidado de activos

La tabla 6 presenta una vision consolidada de los activos mas relevantes, agrupando las categorias anteriores y resaltando su funcion principal dentro del ecosistema DocumentChain.

ID	Activo	Descripcion	Tipo	Criticidad
A-01	Documentos cifrados	Archivos digitales cifrados con AES-256-GCM	Informacion	Critica
A-02	Claves de cifrado	Claves simetricas de documentos encapsuladas	Informacion	Critica
A-03	Credenciales de usuario	Contraseñas (hash bcrypt), tokens JWT	Informacion	Alta
A-04	Claves privadas blockchain	Claves de wallets de usuarios	Informacion	Critica
A-05	Base de datos PostgreSQL	Metadatos, permisos, logs, datos personales	Infraestructura	Alta
A-06	Nodo IPFS	Contenido de documentos almacenado distribuido	Infraestructura	Alta
A-07	Nodo blockchain	Smart contracts y estado de la red	Infraestructura	Alta
A-08	Servidor backend	API REST y logica de negocio	Infraestructura	Alta
A-09	Servidor frontend	Aplicacion web SPA	Infraestructura	Media
A-10	Servidor email	Postfix para notificaciones	Infraestructura	Media
A-11	Reputacion del sistema	Confianza en la autenticidad documental	Organizativo	Alta

Cuadro 6: Resumen consolidado de activos criticos del sistema

3. Etapa 2: Valoracion de activos

En este apartado se valoran los activos previamente identificados para determinar cuales requieren mayor proteccion. Para DocumentChain se ha usado un modelo con cinco dimensiones: confidencialidad, integridad, disponibilidad, trazabilidad y autenticidad, que reflejan los objetivos de seguridad propios de un sistema de gestion documental con evidencias blockchain.

3.1. Criterios de valoracion

A continuacion se definen los cinco criterios de valoracion aplicados:

- **Confidencialidad (C):** Capacidad de garantizar que la informacion solo es accesible para personas o procesos autorizados. Es critica para documentos sensibles, claves criptograficas y datos personales.
- **Integridad (I):** Garantia de que la informacion no ha sido alterada de forma no autorizada. Resulta esencial para los metadatos documentales, los hashes blockchain y los registros de auditoria.
- **Disponibilidad (D):** Capacidad de que los usuarios autorizados puedan acceder a la informacion y a los servicios cuando lo requieran. Es fundamental para el servidor backend, la API REST y los nodos de red.
- **Trazabilidad (T):** Posibilidad de reconstruir el historial completo de operaciones sobre un documento o un usuario. Es un requisito diferenciador de DocumentChain, vinculado directamente a la inmutabilidad blockchain.

- **Autenticidad (A):** Garantía de que la información proviene de la fuente declarada y no ha sido suplantada. Es vital para las firmas digitales, los registros de propiedad y las evidencias on-chain.

3.2. Escala de valoración

Cada criterio se valora en una escala ordinal de 1 a 5, donde 1 representa un impacto insignificante y 5 un impacto catastrófico. La tabla 7 detalla las descripciones asociadas a cada nivel.

Valor	Nivel	Descripción
1	Insignificante	La pérdida o compromiso del activo no afecta al funcionamiento del sistema ni a los usuarios. Puede recuperarse sin coste adicional.
2	Bajo	El impacto es limitado a un subconjunto menor de usuarios o funciones. La recuperación es rápida y el coste asumible.
3	Medio	El impacto afecta a un grupo significativo de usuarios o a procesos operativos. Requiere intervención planificada y recursos moderados.
4	Alto	El compromiso del activo afecta a la totalidad del sistema o a datos sensibles. Puede generar incumplimientos regulatorios y pérdida de confianza.
5	Crítico	El impacto es catastrófico: parada del servicio, pérdida irreversible de datos, violación masiva de privacidad o compromiso de la infraestructura de seguridad.

Cuadro 7: Escala de valoración de activos (1-5)

3.3. Valoración por activo

La tabla 8 recoge la puntuación asignada a cada activo consolidado en las cinco dimensiones definidas. El **valor global** se calcula como la suma ponderada de los criterios, utilizando los pesos siguientes: confidencialidad (25 %), integridad (25 %), disponibilidad (20 %), trazabilidad (15 %) y autenticidad (15 %). La elección de estos pesos refleja la naturaleza documental del sistema, donde la confidencialidad y la integridad prevalecen sobre la disponibilidad, sin menoscabo de la importancia de la trazabilidad y la autenticidad blockchain.

ID	Activo	C	I	D	T	A	Valor
A-01	Documentos cifrados	5	5	4	5	5	4.85
A-02	Claves de cifrado	5	5	3	4	4	4.40
A-03	Credenciales	5	4	4	3	4	4.20
A-04	Claves privadas	5	4	3	5	5	4.55
A-05	Base de datos	5	5	4	4	4	4.60
A-06	Nodo IPFS	4	4	4	4	4	4.00
A-07	Nodo blockchain	4	5	4	5	5	4.55
A-08	Servidor backend	4	4	5	3	3	3.95
A-09	Servidor frontend	3	3	5	2	3	3.20
A-10	Servidor email	4	3	4	2	3	3.40
A-11	Reputacion	4	5	3	4	5	4.25

Cuadro 8: Valoracion de activos por criterios (escala 1-5) y valor global ponderado

Los activos con valor global superior a 4.50 (A-01, A-02, A-04, A-05, A-07, A-11) se consideran de **criticidad extrema** y requieren medidas de proteccion reforzadas. Los activos entre 3.50 y 4.50 (A-03, A-06, A-08) presentan criticidad alta, mientras que los inferiores a 3.50 (A-09, A-10) se clasifican como criticidad media, aunque no por ello se descuidan sus salvaguardas.

4. Etapa 3: Amenazas principales

Para identificar amenazas se han seguido las categorias del metodo MAGERIT adaptadas al catalogo del INCIBE. Se han tenido en cuenta tanto las amenazas genericas de cualquier sistema informatico como las que vienen de usar blockchain, criptografia avanzada y almacenamiento distribuido. En cada amenaza se indica una descripcion tecnica, los activos a los que afecta y una estimacion de probabilidad basada en la frecuencia con la que se ven incidentes similares en el sector.

La escala de probabilidad usada es: **Muy baja (1)**: evento poco probable; **Baja (2)**: posible pero hacen falta condiciones especiales; **Media (3)**: ocurre con cierta frecuencia en el sector; **Alta (4)**: incidente frecuente y bien documentado; **Muy alta (5)**: pasa a menudo si no hay medidas adicionales.

4.1. Amenazas físicas

ID	Amenaza	Descripcion	Activos afectados	Prob.
T-F01	Robo o sustraccion	Sustraccion fisica del portatil de desarrollo o del VPS mediante acceso no autorizado al cloud	A-H02, A-H01	Baja (2)
T-F02	Dano fisico / averia	Fallo de hardware del servidor, deterioro del portatil o incidencias en el centro de datos del proveedor cloud	A-H01, A-H02, A-H03	Baja (2)
T-F03	Desastres naturales	Inundaciones, incendios o terremotos que afecten al proveedor cloud o a la ubicacion local del desarrollador	A-H01, A-H02	Muy baja (1)

Cuadro 9: Amenazas físicas identificadas

4.2. Amenazas lógicas

ID	Amenaza	Descripcion	Activos afectados	Prob.
T-L01	Malware	Infeccion del servidor o del equipo de desarrollo con software malicioso que comprometa la confidencialidad o integridad	A-H01, A-H02, A-S02, A-S05	Media (3)
T-L02	Ransomware	Cifrado malicioso de datos almacenados en el VPS o en el portatil de desarrollo, exigiendo rescate para su recuperacion	A-H01, A-H02, A-D01, A-D05	Baja (2)
T-L03	Spyware / keyloggers	Captura de pulsaciones de teclado o de credenciales mediante software espia en el endpoint del usuario o del administrador	A-P01, A-P03, A-D03	Media (3)

Cuadro 10: Amenazas lógicas identificadas

4.3. Amenazas de denegacion de servicio

ID	Amenaza	Descripcion	Activos afectados	Prob.
T-D01	DDoS distribuido	Saturacion de la capacidad de red o de procesamiento del VPS mediante trafico masivo desde multiples fuentes	A-SV01, A-H01, A-09	Media
T-D02	Saturacion de red local	Consumo excesivo de ancho de banda por parte del nodo IPFS o del nodo blockchain, degradando otros servicios	A-H03, A-SV02, A-H01	Baja
T-D03	Agotamiento de recursos (DoS aplicativo)	Explotacion de operaciones costosas en la API REST o en los smart contracts para consumir gas o CPU de forma deliberada	A-SV01, A-S03	Media

Cuadro 11: Amenazas de denegacion de servicio identificadas

4.4. Amenazas de ingenieria social

ID	Amenaza	Descripcion	Activos afectados	Prob.
T-I01	Phishing generalizado	Envio de correos fraudulentos que suplantando la identidad de DocumentChain para robar credenciales o claves privadas	A-P03, A-D03, A-D06	Alta (4)
T-I02	Spear phishing	Campana de phishing dirigida al desarrollador o a usuarios con privilegios elevados, utilizando informacion personalizada	A-P01, A-P02, A-D03	Media (3)
T-I03	Pretexting / baiting	Manipulacion psicologica para inducir a un usuario a compartir un documento sensible o a firmar una transaccion maliciosa	A-P03, A-D01, A-D03	Baja (2)

Cuadro 12: Amenazas de ingenieria social identificadas

4.5. Amenazas de configuracion y errores operativos

ID	Amenaza	Descripcion	Activos afectados	Prob.
T-C01	Errores de configuracion	Configuracion insegura del servidor, contenedores Docker, base de datos o firewall que exponga servicios o datos	A-H01, A-S02, A-S05	Media (3)
T-C02	Contraseñas debiles	Uso de contraseñas predecibles o reutilizadas por usuarios o administradores, facilitando ataques de fuerza bruta	A-P01, A-P03, A-D06	Alta (4)
T-C03	Error humano	Eliminacion accidental de datos, despliegue incorrecto de contratos o modificacion no autorizada de permisos	A-P01, A-S02, A-S03	Media (3)

Cuadro 13: Amenazas de configuracion identificadas

4.6. Amenazas especificas de blockchain

ID	Amenaza	Descripcion	Activos afectados	Prob.
T-B01	Exploit de smart contract	Explotacion de vulnerabilidades en los contratos inteligentes (reentrancia, desbordamiento, control de acceso deficiente)	A-S03, A-D04, A-11	Baja (2)
T-B02	Front-running	Insertion de transacciones maliciosas con gas superior para alterar el estado de un documento antes de la transaccion legitima	A-S03, A-D04	Baja (2)
T-B03	Ataque al nodo RPC	Manipulacion o censura de las respuestas del nodo RPC que utiliza la aplicacion para interactuar con la blockchain	A-SV02, A-S03	Baja (2)

Cuadro 14: Amenazas especificas de blockchain identificadas

4.7. Amenazas criptograficas

ID	Amenaza	Descripcion	Activos afectados	Prob.
T-CR01	Perdida de claves privadas	El usuario pierde irreversiblemente el acceso a su wallet, impidiendo la firma o la recuperacion de documentos	A-P03, A-D03, A-D01	Media (3)
T-CR02	Ataque a algoritmos	Futura vulnerabilidad de los algoritmos RSA o ECDSA ante computacion cuantica o debilidades criptoanaliticas	A-D02, A-D03, A-D04	Muy baja (1)
T-CR03	Gestion insegura de claves	Almacenamiento de claves en texto plano, sin cifrado de soporte o con copias de seguridad no protegidas	A-P01, A-D02, A-D03	Baja (2)

Cuadro 15: Amenazas criptograficas identificadas

4.8. Amenazas de terceros y cadena de suministro

ID	Amenaza	Descripcion	Activos afectados	Prob.
T-T01	Vulnerabilidades en dependencias	Presencia de vulnerabilidades conocidas (CVE) en librerias npm, Prisma, ethers.js o dependencias transitivas	A-S01, A-S05, A-SV01	Alta (4)
T-T02	Supply chain attack	Compromiso de un paquete de terceros durante su distribucion, inyectando codigo malicioso en la aplicacion	A-S01, A-S05, A-H01	Media (3)
T-T03	Caida del proveedor cloud	Indisponibilidad prolongada del proveedor de infraestructura cloud que aloja el VPS	A-H01, A-SV01, A-SV03	Baja (2)

Cuadro 16: Amenazas de terceros identificadas

4.9. Resumen consolidado de amenazas principales

Para facilitar el analisis de riesgos en etapas posteriores, la tabla 17 sintetiza las amenazas de mayor relevancia, agrupando las categorias anteriores.

ID	Amenaza	Descripcion	Activos afectados	Prob.
T-01	Acceso no autorizado	Intrusion en cuentas de usuario mediante robo o fuerza bruta	A-03, A-05, A-P03	Media (3)
T-02	Perdida de claves	Usuario pierde acceso irreversible a su wallet o claves de cifrado	A-04, A-D02, A-D03	Media (3)
T-03	Ataque al nodo blockchain	Manipulacion o explotacion de smart contracts o del nodo RPC	A-07, A-S03, A-D04	Baja (2)
T-04	Phishing / suplantacion	Engano para obtener credenciales, claves o firmas maliciosas	A-03, A-P03, A-D03	Alta (4)
T-05	Denegacion de servicio (DoS)	Saturacion del servidor backend o agotamiento de recursos	A-08, A-SV01, A-H01	Media (3)
T-06	Perdida de datos	Fallo del servidor de base de datos o corrupcion de datos	A-05, A-S02, A-D05	Baja (2)
T-07	Man-in-the-middle	Intercepcion de comunicaciones entre cliente y servidor o con la blockchain	A-01, A-03, A-D06	Baja (2)
T-08	Malware / ransomware	Infeccion del servidor o endpoints con software malicioso	A-05, A-06, A-H01	Media (3)
T-09	Exfiltracion de datos	Robo de documentos cifrados, metadatos o datos personales	A-01, A-06, A-D05	Baja (2)
T-10	Error humano	Eliminacion accidental, despliegue incorrecto o configuracion insegura	A-05, A-S03, A-P01	Media (3)

Cuadro 17: Amenazas principales consolidadas

5. Etapa 4: Consecuencias y probabilidad

En esta etapa se calcula la exposicion del sistema frente a cada amenaza. Segun el modelo del INCIBE, el **riesgo inherente** sale de multiplicar la **probabilidad** de que ocurra una amenaza por el **impacto** que tendria sobre los activos. Como una misma amenaza puede afectar a varios activos con criticidades distintas, el impacto se toma como el valor maximo de los activos comprometidos.

5.1. Escala de impacto

El impacto se mide en la misma escala ordinal de 1 a 5 utilizada para la valoracion de activos, considerando las dimensiones de confidencialidad, integridad, disponibilidad, trazabilidad y autenticidad:

Valor	Nivel	Descripcion del impacto
1	Insignificante	Sin repercusion operativa, financiera o legal. No requiere accion correctiva.
2	Bajo	Impacto localizado, recuperable en horas sin afectacion a terceros.
3	Medio	Impacto en un subconjunto de usuarios o funciones, posible incumplimiento menor.
4	Alto	Impacto generalizado, posible incumplimiento regulatorio (RGPD) y deterioro de la reputacion.
5	Muy alto	Parada del servicio, perdida masiva de datos, incumplimiento grave o danos irreversibles a la confianza del sistema.

Cuadro 18: Escala de impacto de las consecuencias

5.2. Matriz de riesgos inherente

La tabla 19 presenta el calculo del riesgo inherente para cada amenaza consolidada. El valor del riesgo se obtiene multiplicando la probabilidad (escala 1-5) por el impacto maximo sobre los activos afectados (escala 1-5), resultando en una escala de 1 a 25.

ID	Amenaza	Activos	Prob.	Impacto	Riesgo
T-01	Acceso no autorizado	A-03 (13), A-05 (14)	3	5	15
T-02	Perdida de claves	A-04 (12), A-02 (12)	3	5	15
T-03	Ataque al nodo blockchain	A-07 (13), A-S03 (Critica)	2	5	10
T-04	Phishing / suplantacion	A-03 (13), A-P03 (Media)	4	4	16
T-05	Denegacion de servicio	A-08 (13), A-09 (11)	3	3	9
T-06	Perdida de datos	A-05 (14), A-D05 (Alta)	2	5	10
T-07	Man-in-the-middle	A-01 (14), A-03 (13)	2	5	10
T-08	Malware / ransomware	A-05 (14), A-06 (12)	3	5	15
T-09	Exfiltracion de datos	A-01 (14), A-06 (12)	2	5	10
T-10	Error humano	A-05 (14), A-S03 (Critica)	3	5	15

Cuadro 19: Matriz de riesgos inherente (Probabilidad x Impacto)

5.3. Clasificacion del riesgo

Con base en el valor numerico del riesgo inherente, se establece la siguiente clasificacion cualitativa, representada en la matriz de calor de la tabla 20:

- **Bajo (1-4):** Riesgo asumible con controles estandar. Monitoreo periodico.
- **Medio (5-9):** Riesgo que requiere medidas de mitigacion definidas en el plazo de tres meses.
- **Alto (10-16):** Riesgo que exige medidas inmediatas de mitigacion y supervision continua.
- **Critico (17-25):** Riesgo inaceptable que debe eliminarse o reducirse antes de la puesta en produccion.

Prob. \ Impacto	1 (Insig.)	2 (Bajo)	3 (Medio)	4 (Alto)	5 (Muy alto)
5 (Muy alta)	5 (Medio)	10 (Alto)	15 (Alto)	20 (Critico)	25 (Critico)
4 (Alta)	4 (Bajo)	8 (Medio)	12 (Alto)	16 (Alto)	20 (Critico)
3 (Media)	3 (Bajo)	6 (Medio)	9 (Medio)	12 (Alto)	15 (Alto)
2 (Baja)	2 (Bajo)	4 (Bajo)	6 (Medio)	8 (Medio)	10 (Alto)
1 (Muy baja)	1 (Bajo)	2 (Bajo)	3 (Bajo)	4 (Bajo)	5 (Medio)

Cuadro 20: Matriz de calor de riesgos (Probabilidad x Impacto)

Aplicando esta clasificacion, los riesgos T-01, T-02, T-04, T-08 y T-10 se sitúan en la categoria **Alto**, mientras que T-03, T-05, T-06, T-07 y T-09 se clasifican como **Medio-Alto** (con T-05 y T-09 en el umbral inferior). Ningun riesgo alcanza la categoria Critico tras la primera valoracion, aunque T-04 (phishing) esta proximo al umbral, lo que justifica una atencion prioritaria.

5.4. Medidas de mitigacion propuestas para riesgos altos

Para cada riesgo clasificado como Alto, se proponen medidas de mitigacion preliminares que seran desarrolladas en la Etapa 5. La tabla 21 establece el vinculo entre amenaza y contramedida.

ID	Amenaza	Riesgo	Medidas de mitigacion propuestas
T-01	Acceso no autorizado	15	Verificacion de email, hash de contraseñas con Argon2, control de acceso RBAC, rate limiting y alertas ante intentos fallidos.
T-02	Perdida de claves	15	Restablecimiento seguro de contraseña, copias de seguridad cifradas de claves simetricas e instrucciones de custodia de wallet.
T-04	Phishing	16	Firma de mensaje con wallet, educacion de usuarios, verificacion de dominio en emails, headers anti-phishing.
T-08	Malware	15	Aislamiento Docker, antivirus en endpoints, restriccion de ejecucion de scripts, firmas de imagenes de contenedor.
T-10	Error humano	15	Logs de auditoria completos, separacion de entornos (dev / staging / prod), permisos minimos, procedimientos de despliegue documentados.

Cuadro 21: Medidas de mitigacion propuestas para riesgos altos

6. Etapa 5: Medidas de seguridad

Las medidas de seguridad se han diseñado con un enfoque de defensa en profundidad (*defense in depth*): se superponen varias capas de proteccion, desde prevenir el incidente hasta corregirlo y recuperarse si ocurre. Estan organizadas en cinco categorias: prevencion, deteccion, correccion, proteccion de datos y medidas especificas de blockchain. Esta clasificacion ayuda luego a auditar y a asignar responsabilidades.

6.1. Medidas de prevencion

Las medidas de prevencion tienen como objetivo impedir que las amenazas materialicen un incidente de seguridad. Se centran en el endurecimiento de la superficie de ataque, la gestion robusta de identidades y la validacion estricta de toda la informacion que fluye por el sistema.

- **Políticas de contraseñas robustas:** Se exige longitud minima de 12 caracteres con combinacion de mayusculas, minusculas, numeros y simbolos, ademas de verificacion contra listas de contraseñas filtradas.
- **Verificacion de email y sesiones de corta duracion:** El acceso requiere confirmar el correo electronico y se usan tokens JWT de corta duracion para limitar la exposicion de una sesion comprometida.
- **Rate limiting:** Limite de 100 peticiones por IP cada 15 minutos y 5 intentos de login por cuenta en el mismo periodo, con bloqueo progresivo.
- Validacion de entradas con Zod tanto en frontend como en backend para prevenir inyecciones y otros ataques comunes.
- Headers de seguridad HTTP: CORS restrictivo, CSP, HSTS, X-Frame-Options y X-Content-Type-Options.
- **Control de acceso por roles:** Roles USER y ADMIN con permisos explicitos en cada endpoint y en los smart contracts.

6.2. Medidas de deteccion

La deteccion temprana de actividades anomalas permite contener un incidente antes de que escale. DocumentChain incorpora mecanismos de registro, monitorizacion y alerta en multiples capas.

- **Logs de auditoria centralizados:** Tabla Event en PostgreSQL que registra toda operacion relevante (login, logout, subida de documento, firma, cambio de permisos) con marca temporal, direccion IP y hash de integridad.
- **Monitorizacion de transacciones blockchain:** Escucha de eventos emitidos por los smart contracts (via `ethers.js`) para detectar firmas no autorizadas, intentos de acceso denegados o modificaciones anomalas del estado on-chain.
- **Alertas de seguridad:** Notificaciones automaticas por correo electronico ante eventos criticos (múltiples intentos de login fallidos, cambio de contraseña, eliminacion de cuenta, modificacion de permisos de administrador).
- **Analisis de logs con Winston:** Sistema de logging estructurado en el backend (niveles `info`, `warn`, `error`) con rotacion de ficheros y envio a salida estandar para su recoleccion por agentes externos.

6.3. Medidas de correccion

Las medidas de correccion y recuperacion aseguran la resiliencia del sistema ante incidentes que no han podido prevenirse o detectarse a tiempo.

- **Copias de seguridad periodicas:** Backup automatizado de la base de datos PostgreSQL mediante volcados diarios (`pg_dump`) almacenados en un volumen independiente y, idealmente, en una ubicacion geografica diferente (off-site).
- **Plan de recuperacion ante desastres:** Procedimiento documentado para la restauracion del sistema completo a partir de los backups, incluyendo la recuperacion de contenedores Docker, certificados SSL y configuraciones de red.
- **Invalidacion de sesiones y revocacion de credenciales:** Ante incidentes sobre una cuenta, el backend puede eliminar sesiones activas y exigir un nuevo inicio de sesion, limitando la reutilizacion de tokens comprometidos.
- **Confirmacion reforzada en operaciones destructivas:** Las acciones irreversibles, como la eliminacion de cuenta o el borrado de documentos, requieren confirmacion explicita desde la interfaz para reducir errores operativos.

6.4. Medidas de proteccion de datos

La proteccion de la informacion se materializa mediante cifrado, anonimizacion y politicas de retencion alineadas con el RGPD.

- **Cifrado en transito (TLS 1.3):** Todas las comunicaciones entre cliente y servidor se realizan exclusivamente mediante HTTPS con certificados SSL validos, garantizando confidencialidad y autentificacion del servidor.
- **Cifrado en reposo:** La base de datos PostgreSQL se configura con cifrado a nivel de volumen (LUKS en Linux) y, adicionalmente, las columnas mas sensibles (claves simetricas encapsuladas) se cifran mediante AES-256 antes de su insercion.
- **Cifrado de contenido (AES-256-GCM):** Cada documento se cifra con una clave simetrica unica generada aleatoriamente. Dicha clave se encapsula con la clave publica del destinatario (RSA-OAEP o ECDH sobre P-256), garantizando que unicamente los titulares de la clave privada correspondiente puedan descifrarlo.
- **Anonimizacion y seudonimizacion:** Los datos personales almacenados on-chain se limitan a direcciones de wallet (seudonimos criptograficos), evitando registrar nombres, correos o identificadores directos en la blockchain publica.
- **Derecho al olvido:** Procedimiento para la eliminacion logica de datos personales de la base de datos PostgreSQL cuando el usuario solicita la baja, asi como la revocacion de permisos on-chain asociados a su wallet.

6.5. Medidas especificas de blockchain

Dada la naturaleza irreversible de las transacciones blockchain, se han adoptado medidas especificas para minimizar las vulnerabilidades de los contratos inteligentes y garantizar la correcta gestion de identidades descentralizadas.

- **Auditoria estatica con Slither:** Analisis automatizado del codigo Solidity mediante la herramienta Slither (Trail of Bits) para detectar patrones inseguros, variables sin inicializar, reentrada potencial y violaciones de estandares ERC.

- **Tests de reentrancy:** Ejecucion de pruebas unitarias y de integracion con Hardhat que simulan ataques de reentrada (patron *checks-effects-interactions* y uso de **ReentrancyGuard** de OpenZeppelin).
- **Control de acceso y reentrancia:** Los contratos heredan de **AccessControl** y **ReentrancyGuard** (OpenZeppelin), permitiendo la gestion de roles granulares (**ADMIN_ROLE**, **OPERATOR_ROLE**) y la proteccion de operaciones sensibles frente a reentrancia.
- **Prevencion de overflow/underflow:** Uso de la version de Solidity 0.8.x o superior, donde las operaciones aritmeticas incluyen proteccion automatica contra desbordamiento, complementada con pruebas de fuzzing cuando se utilizan librerias de bajo nivel.

6.6. Tabla resumen de medidas implementadas

La tabla 22 resume las medidas de seguridad implementadas, vinculandolas con las amenazas que mitigan y la categoria funcional a la que pertenecen.

ID	Medida	Implementacion	Amenaza	Categoria
M-01	Cifrado de documentos	AES-256-GCM con clave unica por documento	T-09	Proteccion de datos
M-02	Hash de contraseñas	Argon2 con factor de coste elevado	T-01	Prevencion
M-03	Autenticacion JWT	Tokens de corta duracion (15 min) con refresh token	T-01	Prevencion
M-04	Verificacion de email	Confirmacion previa de la cuenta antes del acceso ordinario	T-01	Prevencion
M-05	Challenge-firma	Firma de mensaje para prueba de posesion de wallet	T-04	Prevencion
M-06	HTTPS/TLS 1.3	Certificado SSL en todas las comunicaciones	T-07	Proteccion de datos
M-07	Control de acceso RBAC	Roles USER y ADMIN con permisos diferenciados	T-01	Prevencion
M-08	Validacion on-chain	Smart contracts verifican permisos en blockchain	T-03	Blockchain
M-09	Logs de auditoria	Tabla Event con trazabilidad de todas las operaciones	T-10	Deteccion
M-10	Docker isolation	Servicios aislados en contenedores con redes internas	T-08	Prevencion
M-11	Rate limiting	100 req/IP/15min, 5 intentos login/15min	T-05	Prevencion
M-12	Backups	Copias de seguridad diarias de PostgreSQL	T-06	Correccion
M-13	Recuperacion de acceso	Restablecimiento seguro de contraseña y revocacion de sesiones	T-02	Correccion
M-14	Validacion de entradas	Zod en frontend y backend para prevenir inyeccion	T-08	Prevencion
M-15	Headers de seguridad	CORS, CSP, HSTS, X-Frame-Options	T-08	Prevencion
M-16	Monitorizacion blockchain	Event listeners para transacciones anomalas	T-03	Deteccion
M-17	Guardas on-chain	Restricciones defensivas del contrato ante estados incompatibles	T-03	Correccion
M-18	Auditoria Slither	Analisis estatico de contratos Solidity	T-03	Blockchain
M-19	ReentrancyGuard	Proteccion contra reentrada en funciones criticas	T-03	Blockchain
M-20	Cifrado en reposo	Volumen LUKS + cifrado de columnas sensibles	T-09	Proteccion de datos

Cuadro 22: Medidas de seguridad implementadas por categoria

7. Proteccion de datos y privacidad

En este apartado se detallan las medidas de proteccion de datos aplicadas en cumplimiento del RGPD y la normativa eIDAS.

La proteccion de datos personales es un pilar del sistema, tanto por obligacion legal (RGPD) como por compromiso con los usuarios. La aplicacion maneja datos identificativos basicos (nombre, correo), datos de sesion, direcciones de wallet y documentos que pueden contener informacion sensible. Por eso se ha seguido un criterio de **minimizacion de datos**: se guarda solo lo imprescindible para autenticar, gestionar documentos, aplicar preferencias de seguridad y mantener la trazabilidad.

7.1. Marco regulatorio: RGPD y eIDAS

El Reglamento General de Proteccion de Datos (RGPD) establece un marco juridico vinculante para el tratamiento de datos personales en el Espacio Economico Europeo. DocumentChain aplica los siguientes principios:

- **Principio de licitud y transparencia:** Los usuarios son informados sobre el tratamiento de sus datos y los derechos que tienen, mediante un aviso de privacidad accesible desde la aplicacion.
- **Principio de minimizacion:** Solo se piden los datos necesarios (usuario, correo, wallet opcional). No se guardan datos bancarios ni documentos de identidad.
- **Principio de integridad y confidencialidad:** Se aplica cifrado, control de acceso y auditoria para proteger los datos personales en todas las fases del tratamiento.

Respecto a la normativa eIDAS, DocumentChain no constituye un prestador de servicios de confianza cualificado, pero aprovecha los mecanismos criptograficos compatibles con dicha regulacion. La firma de documentos mediante wallet Ethereum genera evidencias de autenticidad y no repudio que, aunque no tengan valor juridico reconocido automaticamente como firma electronica cualificada, sirven como prueba electronica de la voluntad del firmante.

7.2. Derechos de los usuarios

En cumplimiento del RGPD, los usuarios pueden ejercer los siguientes derechos mediante solicitud al correo de contacto o desde la interfaz de la aplicacion:

- **Derecho de acceso:** Obtencion de una copia de los datos personales tratados.
- **Derecho de rectificacion:** Correccion de datos inexactos o incompletos.
- **Derecho de supresion (derecho al olvido):** Eliminacion de datos personales cuando ya no sean necesarios, salvo que exista una base legal para su conservacion. En el contexto blockchain, por lo que la red publica es inmutable, no es posible borrar transacciones ya minadas; por ello se anonimiza la relacion entre la direccion de wallet y la identidad del usuario en la base de datos off-chain.
- **Derecho de oposicion:** Posibilidad de oponerse al tratamiento de datos para fines especificos (notificaciones de marketing).
- **Derecho a la portabilidad:** Los usuarios pueden descargar sus documentos cifrados y las claves asociadas para migrar a otro sistema.

7.3. Encriptacion y almacenamiento seguro

DocumentChain combina PostgreSQL para la informacion operativa, IPFS para el almacenamiento documental y blockchain para la trazabilidad de determinadas operaciones. En los documentos privados se aplica un esquema de proteccion que evita que el contenido quede accesible en claro durante el almacenamiento ordinario. En los documentos publicos, en cambio, el sistema mantiene el contenido accesible porque ese es precisamente el objetivo del enlace compartible, por lo que la advertencia al usuario forma parte de la propia medida de seguridad.

7.3.1. Cifrado en reposo

La base de datos PostgreSQL se aloja en un volumen cifrado mediante LUKS (Linux Unified Key Setup) en el servidor de produccion. Adicionalmente, las columnas que almacenan claves simetricas encapsuladas y tokens de recuperacion se cifran a nivel aplicacion mediante AES-256-GCM antes de su persistencia. Esta doble capa garantiza que, incluso en caso de acceso no autorizado al volumen de almacenamiento o a una copia de seguridad, los datos sensibles permanezcan indescifrables sin la clave maestra del servicio.

7.3.2. Cifrado en transito

Todas las comunicaciones entre el cliente (navegador) y el servidor backend se establecen exclusivamente mediante HTTPS con TLS 1.3, utilizando certificados SSL de una autoridad de certificacion reconocida. La configuracion del servidor web (Nginx) rechaza conexiones no cifradas y fuerza la negociacion de suites criptograficas seguras, excluyendo protocolos obsoletos (SSLv2, SSLv3, TLS 1.0, TLS 1.1) y algoritmos debiles (MD5, SHA-1, RC4).

7.3.3. Cifrado de contenido (AES-256-GCM)

El esquema de cifrado hibrido implementado en DocumentChain funciona de la siguiente manera. Primero, se genera una clave simetrica aleatoria de 256 bits para cada documento usando un generador criptograficamente seguro (CSPRNG). A continuacion, el fichero se cifra con AES-256-GCM, que genera un nonce unico de 96 bits y una etiqueta de autenticacion de 128 bits, garantizando confidencialidad e integridad al mismo tiempo. Por ultimo, la clave simetrica se encapsula con la clave publica del destinatario mediante RSA-OAEP con SHA-256 o mediante ECDH sobre P-256, por lo que solo quien tenga la clave privada puede recuperarla.

Este esquema hibrido combina la eficiencia del cifrado simetrico para grandes volúmenes de datos con la seguridad del cifrado asimétrico para el intercambio de claves.

7.4. Control de acceso y autenticacion

En la interfaz principal, el acceso a la cuenta se realiza mediante usuario o correo y contraseña. La verificación previa del email actúa como condición para el acceso ordinario y la wallet queda reservada para la firma de operaciones blockchain, sin utilizarse como mecanismo principal de autenticación dentro del flujo habitual.

7.4.1. Autenticacion basada en JWT

Tras la validación de credenciales y la comprobación del estado verificado de la cuenta, el backend emite un JSON Web Token (JWT) firmado con una clave secreta de servidor (HS256). El token contiene el identificador de usuario, su rol y una marca de expiración (15 minutos). Un token de refresco (refresh token) de mayor duración (7 días) permite la renovación transparente de la sesión sin solicitar nuevamente las credenciales. Los tokens se almacenan en memoria local del navegador (`sessionStorage`) para minimizar el riesgo de exfiltración persistente.

7.4.2. Autorizacion RBAC y ABAC

La autorizacion se articula en dos niveles complementarios:

- **RBAC (Role-Based Access Control):** Los usuarios se clasifican en roles (USER, ADMIN) que determinan los permisos sobre los endpoints de la API REST. Por ejemplo, unicamente los usuarios con rol ADMIN pueden acceder al panel de administracion, gestionar cuentas o modificar parametros del sistema.
- **ABAC (Attribute-Based Access Control):** A nivel de documento individual, los permisos se evaluan en funcion de atributos dinamicos: propiedad del documento, relacion de comparticion, estado de firma requerida y permisos on-chain registrados en el smart contract `AccessControl`.

7.4.3. Control de acceso on-chain

Los smart contracts mantienen un registro de permisos que condicionan las operaciones ejecutadas sobre la blockchain. Cada funcion critica (registro de documento, firma, versionado, transferencia de propiedad) verifica que la direccion que invoca la transaccion posea el rol adecuado o figure como destinatario autorizado en el mapping de permisos. Esta comprobacion es inmutable y auditable, proporcionando una capa adicional de control que no depende exclusivamente del backend.

8. Componentes criticos del software

En este apartado se analizan los componentes cuyo compromiso tendria un impacto directo sobre la seguridad del sistema.

La seguridad del sistema depende especialmente de unos pocos componentes cuya alteracion tendria un impacto directo sobre la confidencialidad, la integridad o la disponibilidad del servicio. A continuacion se analiza cada componente critico, sus vectores de ataque principales y las salvaguardas especificas aplicadas.

8.1. Backend y API REST

El backend concentra la logica de negocio, la validacion de permisos, la preparacion de operaciones blockchain y la coordinacion entre base de datos, IPFS y servicios auxiliares. Un fallo en esta capa podria afectar simultaneamente al acceso a documentos, al control de usuarios y a la consistencia de los estados operativos. De ahi que se haya priorizado la validacion de entradas, la separacion de responsabilidades entre servicios y el registro de eventos relevantes.

8.1.1. Medidas de seguridad del backend

- **Rate limiting y throttling:** Uso de la libreria `express-rate-limit` para restringir el numero de peticiones por IP y por usuario, previniendo ataques de fuerza bruta y denegacion de servicio a nivel aplicativo.
- **Validacion estricta de entradas:** Todas las entradas de la API se validan mediante esquemas Zod antes de su procesamiento. Se rechazan campos no esperados, tipos incorrectos y valores fuera de rango, mitigando inyecciones y desbordamientos.
- **Autenticacion stateless JWT:** La sesion se materializa en un token JWT firmado con HMAC-SHA256 y una clave secreta de servidor. No se utilizan sesiones de servidor (stateless) para facilitar la escalabilidad horizontal y reducir el riesgo de secuestro de sesion en memoria.

- **Separacion de responsabilidades:** El codigo del backend sigue una arquitectura por capas (controllers, services, repositories) que evita el acoplamiento entre logica de negocio y acceso a datos, facilitando la auditoria y los tests de seguridad.
- **Gestion segura de secretos:** Las claves privadas del servidor, las contraseñas de base de datos y las claves de firma JWT se gestionan mediante variables de entorno y, en produccion, se recomienda el uso de un gestor de secretos (HashiCorp Vault, AWS Secrets Manager o similar).

8.2. Base de datos, IPFS y blockchain

PostgreSQL conserva usuarios, sesiones, metadatos, notificaciones y proyecciones operativas del sistema. IPFS aloja el contenido documental y blockchain registra las evidencias de determinadas operaciones criticas. Ninguno de estos elementos funciona de manera aislada: la aplicacion necesita contrastar lo almacenado, lo publicado y lo firmado para mantener un estado coherente.

8.2.1. Copias de seguridad y redundancia

- **Backups de PostgreSQL:** Volcados diarios automatizados mediante `pg_dump` comprimidos y almacenados en un volumen independiente del servidor principal. Se conservan copias de los ultimos 30 dias con politica de rotacion.
- **Redundancia IPFS:** El nodo IPFS se configura con *pinning* persistente de los contenidos documentales. Se recomienda la replicacion en multiples nodos (IPFS cluster o servicios de pinning comerciales) para evitar la perdida de datos si un unico nodo queda inaccesible.
- **Persistencia blockchain:** Los datos on-chain son inherentemente redundantes por la naturaleza distribuida de la red Ethereum. No obstante, los eventos emitidos por los contratos se almacenan tambien en PostgreSQL (tabla `Event`) para permitir consultas rapidas sin depender exclusivamente del nodo RPC.

8.2.2. Validacion de integridad

- **Checksums de documentos:** Antes del cifrado, se calcula el hash SHA-256 del contenido original. Este hash se registra on-chain, permitiendo verificar posteriormente que el documento descifrado coincide con la version original.
- **Integridad referencial:** La base de datos utiliza claves foraneas y restricciones `ON DELETE` controladas para evitar inconsistencias entre usuarios, documentos, versiones y permisos.
- **Sincronizacion on-chain / off-chain:** Un servicio de *event listener* escucha los eventos del smart contract y actualiza la base de datos PostgreSQL de forma transaccional. En caso de discrepancia, se genera una alerta para revision manual.

8.3. Frontend y gestion de sesiones

El frontend es responsable de presentar informacion sensible, gestionar el estado de la sesion y guiar al usuario en operaciones que pueden modificar documentos o registrar evidencias en blockchain. Se ha procurado que las rutas protegidas no queden expuestas fuera del contexto autenticado y que las acciones de riesgo alto, como publicar contenido o firmar operaciones, se muestren de forma explicita y con confirmaciones adecuadas.

8.3.1. Proteccion contra vulnerabilidades web

- **Proteccion XSS (Cross-Site Scripting):** El framework React escapa automaticamente las interpolaciones en JSX. Se evita el uso de `dangerouslySetInnerHTML` y se sanitizan los mensajes de error mostrados al usuario.
- **Proteccion CSRF (Cross-Site Request Forgery):** Al utilizar autenticacion stateless JWT almacenada en `sessionStorage` (no en cookies), el riesgo de CSRF se reduce significativamente. Las peticiones a la API incluyen el token en la cabecera `Authorization: Bearer`.
- **Proteccion contra clickjacking:** La cabecera HTTP `X-Frame-Options: DENY` impide que la aplicacion sea embebida en `iframe` de terceros, neutralizando ataques de clickjacking.
- **Almacenamiento seguro de tokens:** Los tokens JWT se almacenan en `sessionStorage` (persistente durante la sesion del navegador) en lugar de `localStorage`, reduciendo la ventana de exposicion ante ataques XSS. El refresh token se gestiona mediante una cookie `HttpOnly` y `Secure` si la arquitectura lo permite.

8.3.2. Experiencia de usuario segura

La interfaz tambien participa en la seguridad al distinguir con claridad cuando un documento es privado, cuando ha sido archivado y cuando ha pasado a ser publico mediante enlace o codigo QR. Esa diferenciacion reduce errores de uso y ayuda a que el comportamiento del sistema resulte previsible para el usuario. Las acciones destructivas (eliminacion de documentos, revocacion de permisos, firma blockchain o eliminacion de cuenta) requieren confirmacion modal explicita y, cuando procede, una confirmacion adicional por parte del usuario.

8.4. Smart contracts

Los contratos inteligentes representan el componente mas critico desde la perspectiva de la inmutabilidad: una vez desplegados, su codigo no puede modificarse. Por ello, la deteccion y correccion de vulnerabilidades debe producirse *antes* del despliegue en red principal.

8.4.1. Medidas especificas de seguridad en Solidity

- **Prevencion de overflow/underflow:** Uso de Solidity 0.8.x, donde las operaciones aritmeticas incluyen comprobaciones automaticas de rango. En caso de requerir librerias externas (OpenZeppelin), se utilizan funciones seguras como `SafeMath` solo cuando es estrictamente necesario.
- **Proteccion contra reentrancy:** Aplicacion del patron *checks-effects-interactions*: primero se validan las precondiciones, despues se actualizan los estados internos y finalmente se realizan las llamadas externas. Ademias, los contratos heredan de `ReentrancyGuard` de OpenZeppelin, que bloquea las llamadas reentrantes mediante un mutex.
- **Control de acceso riguroso:** Uso de `AccessControl` en lugar de `Ownable` para definir roles granulares. Las funciones administrativas y de gobierno del contrato estan protegidas por modificadores que verifican el rol correspondiente.
- **Guardas defensivas del contrato:** Los modificadores de validacion y las comprobaciones de preestado reducen la superficie de ataque y evitan transiciones inconsistentes sin alterar la inmutabilidad del historial ya publicado.

- **Verificación de fuente:** Tras el despliegue, el código fuente de los contratos se verifica públicamente en el explorador de bloques (Etherscan o equivalente), permitiendo a usuarios y auditores independientes comprobar que el bytecode desplegado corresponde al código auditado.

9. Etapa 6: Riesgos residuales

En este apartado se identifican los riesgos que persisten tras la aplicación de las medidas de seguridad y se establece un plan de aceptación.

Aunque se hayan aplicado todas las medidas descritas, siempre quedan riesgos residuales por limitaciones técnicas, de coste o por el factor humano. Esta etapa identifica esos riesgos que persisten, les asigna un nivel y establece un plan de aceptación o tratamiento.

Para valorar el riesgo residual se reevalúan la probabilidad y el impacto de cada amenaza después de aplicar las medidas. Se usa la misma escala y matriz de calor de la Etapa 4.

9.1. Tabla de riesgos residuales

A continuación se presentan los riesgos que permanecen tras la aplicación de las salvaguardas.

La tabla 23 detalla los riesgos que permanecen tras la aplicación de las salvaguardas, indicando las medidas aplicadas, el riesgo inherente inicial y el riesgo residual calculado.

ID	Amenaza	Riesgo inicial	Medidas aplicadas	Riesgo residual	Nivel
T-01	Acceso no autorizado	15	M-02, M-03, M-04, M-07, M-11	6	Medio
T-02	Pérdida de claves	15	M-13, educación de usuario	5	Medio
T-03	Ataque al nodo blockchain	10	M-08, M-16, M-17, M-18, M-19	4	Bajo
T-04	Phishing	16	M-04, M-05, M-15, concienciación	6	Medio
T-05	DoS	9	M-11, M-10, firewall	4	Bajo
T-06	Pérdida de datos	10	M-12, M-20, redundancia	4	Bajo
T-07	Man-in-the-middle	10	M-06, certificados SSL	4	Bajo
T-08	Malware	15	M-10, M-14, M-15, antivirus	6	Medio
T-09	Exfiltración de datos	10	M-01, M-20, cifrado	4	Bajo
T-10	Error humano	15	M-09, M-12, procedimientos	6	Medio

Cuadro 23: Riesgos residuales tras las medidas aplicadas

Como se observa, ningún riesgo residual alcanza la categoría Alto o Crítico. Los riesgos T-01, T-02, T-04, T-08 y T-10 se mantienen en nivel Medio, principalmente debido a la imposibilidad de eliminar completamente el factor humano (errores, phishing, pérdida de credenciales) mediante controles técnicos exclusivos.

9.2. Plan de aceptacion de riesgos

Los riesgos residuales de nivel Medio se consideran aceptables para el contexto operativo actual del sistema, siempre que se cumplan las siguientes condiciones:

- **Riesgo T-01 (Acceso no autorizado):** Se acepta bajo la condicion de que el sistema mantenga la verificacion de email, el endurecimiento de sesiones y la revision periodica de los logs de acceso. Se requiere notificacion inmediata ante multiples intentos fallidos.
- **Riesgo T-02 (Pérdida de claves):** Se acepta con la salvedad de que los usuarios deben ser informados explicitamente sobre la imposibilidad de recuperar documentos si pierden tanto su wallet como sus codigos de recuperacion. Se recomienda el uso de hardware wallets para usuarios avanzados.
- **Riesgo T-04 (Phishing):** Se acepta asumiendo que una parte de los usuarios puede ser victima de engaños. La mitigacion depende de la educacion continua y de la verificacion de dominios, pero no puede garantizarse al 100 %.
- **Riesgo T-08 (Malware):** Se acepta bajo la premisa de que el sistema de deteccion de intrusiones y los aislamientos Docker contienen la propagacion. La responsabilidad de la seguridad del endpoint corresponde al usuario.
- **Riesgo T-10 (Error humano):** Se acepta reconociendo que los procedimientos documentados y los entornos separados reducen, pero no eliminan, la probabilidad de errores operativos.

9.3. Plan de mejora continua

En este apartado se establece el programa de mejora continua para la gestion de riesgos del sistema.

La gestion de riesgos no concluye con la redaccion de este anexo, por lo que se establecen las siguientes actividades:

- **Auditorias de seguridad periodicas:** Revision trimestral de la configuracion del servidor, permisos de acceso, politicas de contraseñas y estado de las dependencias software.
- **Pruebas de penetracion (pentesting):** Ejecucion anual de pentesting externo sobre la API REST y el frontend, asi como auditoria de smart contracts antes de cada despliegue mayor en red principal.
- **Actualizacion de dependencias:** Monitoreo continuo de vulnerabilidades publicadas (CVE) en las librerias npm, Prisma, Docker y OpenZeppelin mediante herramientas como GitHub Dependabot y `npm audit`. Aplicacion de parches de seguridad en un plazo maximo de 7 dias para vulnerabilidades criticas.
- **Revision de logs y alertas:** Analisis semanal automatizado de los logs de auditoria para detectar patrones anomalos, intentos de acceso no autorizado o variaciones inesperadas en el trafico.
- **Formacion y concienciacion:** Sesiones anuales de formacion en seguridad para el equipo de desarrollo y administracion, enfocadas en las amenazas emergentes del ecosistema blockchain y web.

10. Metodologías y herramientas

En este apartado se describen los marcos metodológicos y las herramientas empleadas en la elaboración del plan de seguridad.

La elaboración del presente plan de seguridad se ha fundamentado en metodologías reconocidas internacionalmente y en herramientas específicas que permiten automatizar la detección de vulnerabilidades.

10.1. Marcos metodológicos

- **Plan Director de Seguridad (INCIBE):** Marco metodológico oficial seguido para la elaboración de este anexo. Proporciona las seis etapas secuenciales (identificación, valoración, amenazas, consecuencias, medidas y riesgos residuales) que garantizan una cobertura sistemática de la gestión de riesgos.
- **OWASP Top 10:** Referencia de facto para la identificación y mitigación de las vulnerabilidades web más críticas. Se ha utilizado como checklist durante el diseño del backend y el frontend, asegurando la protección contra inyecciones, XSS, CSRF, autenticación rota y configuraciones inseguras.
- **MAGERIT:** Metodología de análisis y gestión de riesgos de las tecnologías de la información del Ministerio de Hacienda y Función Pública de España. Ha servido de complemento para la categorización de amenazas y la valoración de activos.
- **ESTIMA:** Guía del INCIBE para la gestión de incidentes de ciberseguridad, utilizada como referencia para la definición del plan de mejora continua y la respuesta ante incidentes.

10.2. Herramientas de seguridad

La tabla 24 recoge las principales herramientas de seguridad utilizadas durante el ciclo de vida del proyecto, indicando su propósito, el componente sobre el que actúan y la fase del desarrollo en la que se emplean.

Herramienta	Proposito	Componente	Fase
Slither (Trail of Bits)	Analisis estatico de vulnerabilidades en Solidity	Smart contracts	Desarrollo / CI
Echidna (Trail of Bits)	Fuzzing de propiedades en contratos inteligentes	Smart contracts	Testing
Mythril (ConsenSys)	Analisis simbolico de seguridad en EVM bytecode	Smart contracts	Desarrollo
OWASP ZAP	Escaneo de vulnerabilidades web (DAST)	Frontend / API REST	Testing / Pentesting
npm audit	Deteccion de vulnerabilidades en dependencias npm	Frontend / Backend	Desarrollo / CI
GitHub Dependabot	Alertas automaticas de CVE en dependencias	Todo el proyecto	Monitorizacion continua
ESLint + SonarJS	Analisis estatico de calidad y seguridad de codigo JS/TS	Frontend / Backend	Desarrollo / CI
Docker Bench Security	Auditoria de configuraciones seguras de Docker	Infraestructura	Despliegue

Cuadro 24: Herramientas de seguridad utilizadas

10.2.1. Analisis estatico de smart contracts

- **Slither:** Ejecutado sobre el codigo fuente Solidity para detectar patrones inseguros, variables sin inicializar, funciones que deberian ser **view** o **pure**, y vulnerabilidades conocidas (reentrancia, control de acceso deficiente). Genera un informe en formato JSON integrado en la pipeline de CI.
- **Echidna:** Utilizado para pruebas de fuzzing orientadas a propiedades (*property-based testing*). Se definen invariantes del sistema (por ejemplo, únicamente el propietario puede transferir un documento”) y Echidna genera entradas aleatorias para intentar violarlas.
- **Mythril:** Herramienta de analisis simbolico que explora los caminos de ejecucion del contrato inteligente, buscando condiciones que permitan el acceso no autorizado, la manipulacion de almacenamiento o el consumo excesivo de gas.

10.2.2. Pruebas de seguridad de aplicaciones web

- **OWASP ZAP (Zed Attack Proxy):** Utilizado como proxy de interceptacion durante las pruebas de penetracion manuales y como escaner activo durante la fase de testing. Permite detectar XSS reflejado y persistente, inyecciones SQL, configuraciones CORS permisivas y exposicion de informacion sensible en headers o respuestas.

10.3. Metodologia de pentesting aplicada

Las pruebas de penetracion se han estructurado siguiendo el **OWASP Testing Guide v4.2**, abordando las siguientes areas:

1. **Reconocimiento y mapeo de la aplicacion:** Identificacion de endpoints, parametros, tecnologias y dependencias expuestas.
2. **Gestion de identidades y autentificacion:** Pruebas de fuerza bruta, bypass de autentificacion, manipulacion de tokens JWT y secuestro de sesiones.
3. **Autorizacion:** Escalada de privilegios horizontales y verticales, acceso a funciones administrativas sin rol correspondiente.
4. **Validacion de entradas:** Inyecciones SQL, NoSQL, XSS, command injection, path traversal y deserializacion insegura.
5. **Logica de negocio:** Manipulacion de flujos de firma, intento de doble gasto en evidencias blockchain y evasion de controles de permisos on-chain.
6. **Seguridad en el cliente:** Analisis del almacenamiento local, deteccion de secretos en el bundle de React y validacion de la configuracion CSP.
7. **Criptografia:** Verificacion de la longitud de claves, aleatoriedad de nonces, almacenamiento seguro de claves privadas y resistencia a replay attacks en los mensajes de firma con wallet.

Los resultados de cada fase se documentan en un informe de pentesting interno que incluye la descripcion de la vulnerabilidad, su criticidad, evidencias (capturas de pantalla, peticiones HTTP) y la recomendacion de remedio. Las vulnerabilidades criticas y altas deben corregirse antes de cualquier despliegue en produccion.

10.4. Politica de actualizacion de dependencias

La gestion proactiva de dependencias es esencial para mitigar riesgos de cadena de suministro y vulnerabilidades conocidas. Se ha establecido la siguiente politica:

- **Monitorizacion continua:** GitHub Dependabot esta configurado para escanear diariamente el repositorio y generar alertas cuando una dependencia directa o transitiva presente una vulnerabilidad publicada (CVE).
- **Ejecucion de npm audit:** Integrado en la pipeline de integracion continua (CI). Cualquier pull request que introduzca una vulnerabilidad *high* o *critical* bloquea la fusion hasta su resolucion.
- **Plazos de remediacion:**
 - Vulnerabilidades criticas (CVSS 9.0-10.0): maximo 24-48 horas.
 - Vulnerabilidades altas (CVSS 7.0-8.9): maximo 7 dias.
 - Vulnerabilidades medias (CVSS 4.0-6.9): maximo 30 dias.
 - Vulnerabilidades bajas (CVSS 0.1-3.9): maximo 90 dias o proximo ciclo de mantenimiento.
- **Pinning de versiones:** Las dependencias se fijan mediante ficheros `package-lock.json` y `yarn.lock` para garantizar reproducibilidad de builds y evitar la instalacion inadvertida de versiones comprometidas.
- **Revision de librerias blockchain:** Las librerias `ethers.js`, `hardhat` y los contratos de OpenZeppelin se actualizan unicamente tras revisar las notas de version y el historial de auditorias publicas, dado su impacto directo en la seguridad de los activos criptograficos.

11. Conclusiones

El Plan de Seguridad de DocumentChain ha identificado, valorado y mitigado los riesgos de un sistema que junta tecnologías muy distintas y con requisitos de seguridad exigentes. Seguir la metodología INCIBE en sus seis etapas ha permitido abordar la seguridad de forma ordenada: se han identificado 26 activos críticos y se han definido 20 medidas de seguridad que cubren prevención, detección, corrección y protección de datos.

Después de aplicar esas medidas, el análisis muestra que todos los riesgos residuales están en niveles aceptables (Bajo o Medio), sin que ninguno llegue a Alto o Crítico. Las medidas que más han ayudado han sido el cifrado de extremo a extremo (AES-256-GCM + ECDH), la verificación de email junto con el endurecimiento de sesiones, la validación de permisos on-chain mediante el contrato DocumentRegistry y el aislamiento de servicios con Docker.

Aun así, el plan reconoce limitaciones que habría que abordar en el futuro: falta una auditoría de seguridad profesional del contrato inteligente, se depende de un único nodo IPFS autoalojado y convendría montar un sistema de detección de intrusiones (IDS) y hacer pruebas de penetración periódicas.

Glosario

AES-256-GCM Advanced Encryption Standard con clave de 256 bits en modo Galois/Counter Mode. Proporciona confidencialidad y autenticación simultáneas.

CIA Confidencialidad, Integridad y Disponibilidad. Triada clásica de la seguridad de la información.

CVSS Common Vulnerability Scoring System. Sistema estandarizado de puntuación de vulnerabilidades.

ECDH Elliptic Curve Diffie-Hellman. Protocolo de intercambio de claves basado en curvas elípticas (P-256).

EIP-6963 Multi Injected Provider Discovery. Estandar para detección de múltiples wallets en el navegador.

INCIBE Instituto Nacional de Ciberseguridad de España. Referencia metodológica para el Plan Director de Seguridad.

JWT JSON Web Token. Token de autenticación firmado digitalmente.

OWASP Open Web Application Security Project. Organización que publica el Top 10 de riesgos de seguridad web.

RBAC Role-Based Access Control. Control de acceso basado en roles.

RGPD Reglamento General de Protección de Datos (UE 2016/679).

Referencias

- [1] INCIBE (2023). “Plan Director de Seguridad”. Instituto Nacional de Ciberseguridad.
- [2] OWASP Foundation (2021). “OWASP Top 10:2021”. <https://owasp.org/Top10/>
- [3] Unión Europea (2016). “Reglamento (UE) 2016/679 (RGPD)”. Diario Oficial de la Unión Europea.

- [4] Union Europea (2014). “Reglamento (UE) 910/2014 (eIDAS)”. Diario Oficial de la Union Europea.
- [5] OpenZeppelin (2023). “OpenZeppelin Contracts Documentation v5.0”.
- [6] Trail of Bits (2023). “Smart Contract Security Field Guide”.
- [7] NIST (2023). “National Vulnerability Database”. National Institute of Standards and Technology.